

100 Days of Azure DevOps

Day 69 Handout — Who can edit YAML can ship — branch policy, env approvals, one connection per environment

7 - Security, Compliance & Governance · Personal lab only · Educational content · Not a sales pitch

Architecture A — controls around the YAML, not only inside it

Control	Where	Failure if missing
Branch policy on main	Repos → Branches → min reviewers + required build	A Contributor pushes to main and skips Security
Who can edit pipelines	Project → Pipelines security / repo ACL	Approvals are a speed bump around a hole — anyone rewrites Deploy
Environment approval	Pipelines → Environments → lab/prod → Approvals	deployment: job goes to prod from a feature branch unattended
Service connection scope	lab-sc → rg-lab. prod-sc → rg-prod. Not one azure Owner	Day 63 master key with a friendly name
Agent threat model	Hosted ubuntu-latest for these labs	Self-hosted with org-wide creds is lateral movement as a hobby

Architecture B — decide prod drama vs lab boredom

Question	Lab default	Prod-shaped habit
Who approves	You (email on the environment)	A group, not a shared password
Which branch deploys	main only via environment + checks	Feature branch with a prod connection — never
Secrets in logs	Day 65 length-only; debug off	system.debug on a KV job is how incidents write themselves
SPN leftover	Remove Owner from lab-sc if still present	An old Owner SPN from 'the wizard' is in-scope today
Templates	Optional; do not hide Owner in a template nobody reads	Reviewed YAML still beats folklore

Architecture C — pitfalls that look like security and still ship from a fork

Pitfall	What you see	Fix
Approval on the wrong environment	Deploy job uses environment: none	job type: deployment + environment: lab
Open main	Direct pushes, required check never runs	Branch policy: require pull request
Same SC for lab and 'prod'	rg-prod deleted from a lab experiment	Two connections, two RGs, two identities
Secret echo still on	Logs from Day 65 regress	Re-read the length-only step
Cannot answer who can ship	Hope	The audit is the lab. Write names/roles from the personal org

One-liner to remember

A secure pipeline is boring on purpose — drama belongs in fiction, not release logs. If you cannot answer who can ship, you do not have a secure pipeline.

Step-by-step lab (personal Azure / Azure DevOps only)

Personal Azure DevOps org only. Audit azure-100-labs. Remove leftover Owner SPNs you created in this series.

- 1 Audit: Project Settings → Permissions / Pipelines. Who can edit pipeline YAML? Write the list (it may be only you). If Contributors can rewrite prod stages, note it as a finding.
- 2 Repos → Branches → main: require a pull request (even if you are the only reviewer in a personal org). Required check = the pipeline with Security.
- 3 Pipelines → Environments → create lab. Add an Approval (your user). Change Deploy to a deployment job with environment: lab.
- 4 Inspect lab-sc (and any second connection). Remove subscription Owner if present. Confirm it cannot see a RG you did not intend. Separate names if you already have a prod-shaped RG.
- 5 Re-check no secret echo / system.debug on Key Vault jobs. Tick a checklist file docs/secure-pipeline-day69.md: connections per env, no secret echo, main locked, approval on.
- 6 Do not use an employer org for this audit. Boring is the outcome.

Starter YAML — deployment job hits an environment with approvals

```
stages:
- stage: DeployLab
  jobs:
  - deployment: toLab
    pool: { vmImage: ubuntu-latest }
    environment: lab    # Approvals live on this environment
    strategy:
      runOnce:
        deploy:
          steps:
            - checkout: self
            - task: AzureCLI@2
              inputs:
                azureSubscription: lab-sc    # not prod-sc, not subscription Owner
                scriptType: bash
                scriptLocation: inlineScript
                inlineScript: echo "lab RG only"

# Checklist (also in docs):
# - separate service connections per env
# - no secret echo / system.debug off on KV jobs
# - main locked with PR + required build
# - prod/lab approval required
```

Done checklist

- Can name who can edit pipelines and who can approve lab
- main has a PR policy; Deploy uses environment: lab
- lab-sc is not subscription Owner
- docs/secure-pipeline-day69.md checklist ticked

Tomorrow — Day 70

Phase 7 mini project — secret not in YAML, policy visible, approvals on